

MÓDULO 1
Seguridad Informática
y Criptografía
Ciberseguridad

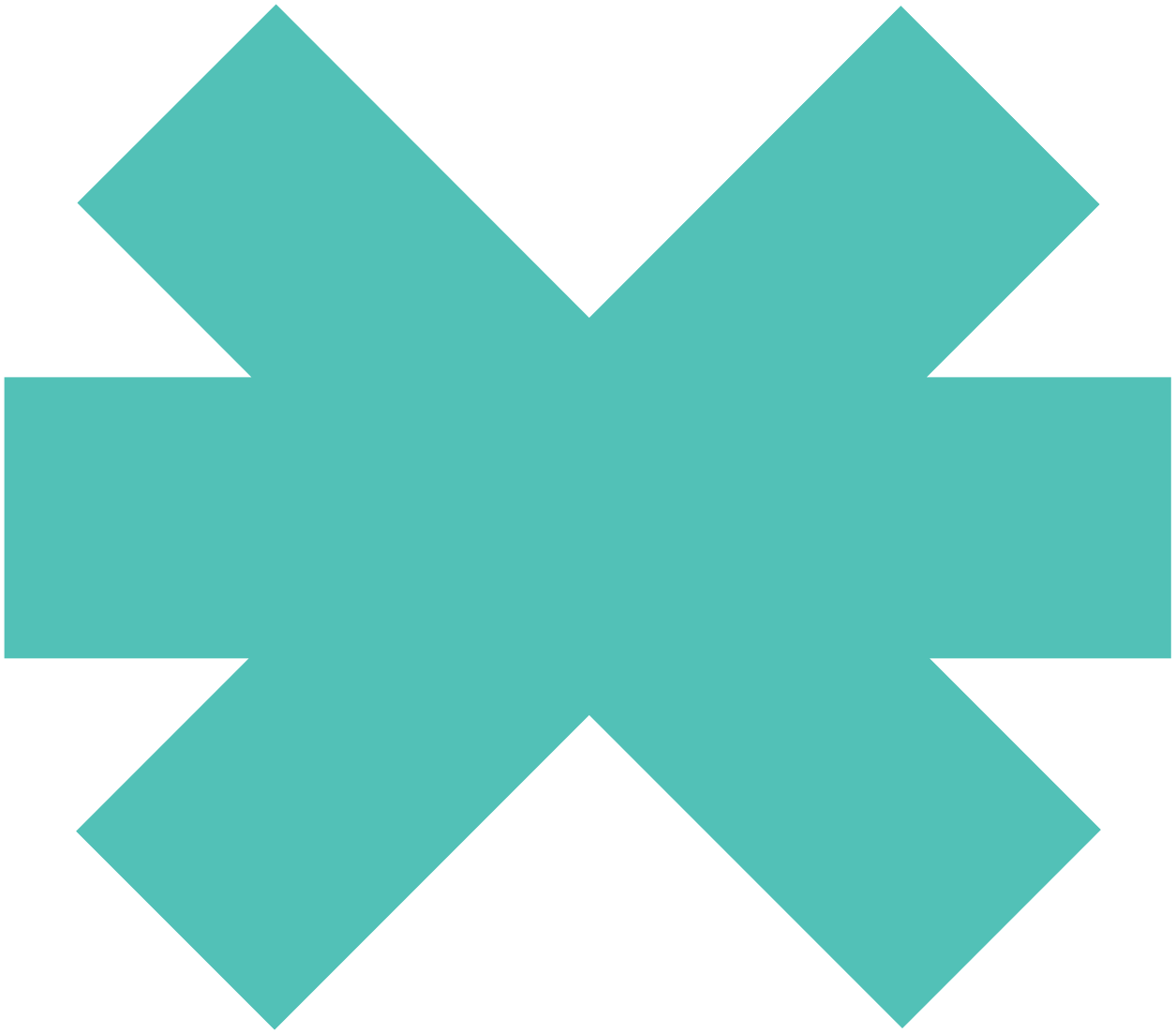
6

Firma digital



New
Technology
School

Tokio.



6 Firma digital

Sumario

6.1	Flujo de la firma digital	86
6.2	Certificados digitales	89
6.3	<i>Hash</i>	94

6.1 Flujo de la firma digital

Actualmente, lo más común es la **firma manuscrita**, que dota de valor a un contrato dirigido a establecer un acuerdo entre dos o más partes. Sus **características** son las siguientes:

- Es reconocible.
- Prueba quién es el remitente del mensaje.
- El receptor puede identificar quién es el emisor tras comprobar que la firma es auténtica.
- La firma forma parte del documento y no se puede repudiar.
- El documento firmado es inalterable.
- Posee validez legal.

La **firma digital**, por su parte, es un **mecanismo criptográfico** que permite identificar a la entidad donde se origina el mensaje, de forma que se garantiza la **autenticación de origen** y el **no repudio**. Se trata de una de las aportaciones de la criptografía de clave pública, que soluciona uno de los principales inconvenientes de tales criptosistemas: dado que las claves son públicas, un usuario o una usuaria malintencionados podrían usar la clave pública de otro usuario/a con el objeto de suplantar su identidad.

Los **problemas que soluciona** son los siguientes:

- Debe ser fácil de generar.
- Será irrevocable, esto es, no rechazable por su propietario/a.
- Será única, pues solo podrá generarla su propietario/a.
- Será fácil de autenticar o reconocer por parte de su propietario/a y por los usuarios y las usuarias receptores.
- Debe depender del mensaje y del autor/a.

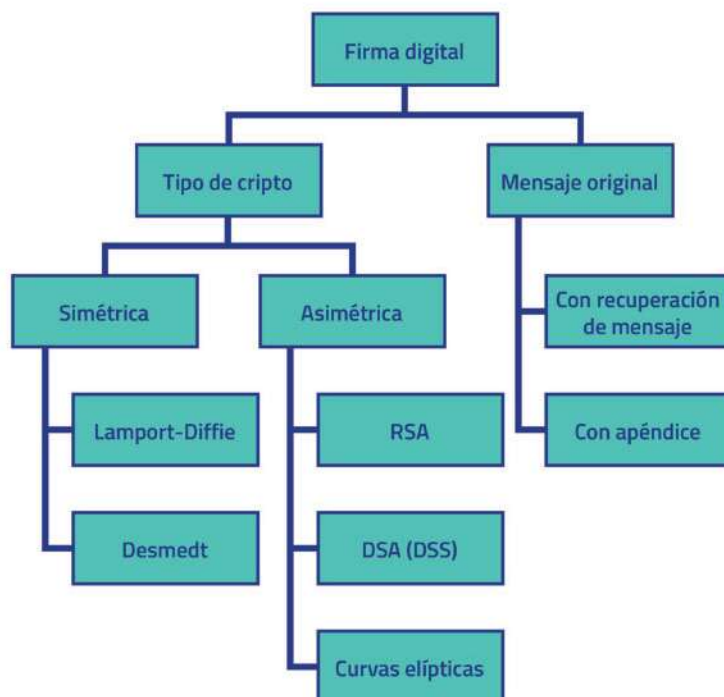


Figura 53

La norma que regula la firma electrónica en España es la **Ley 59/2003**, de 19 de diciembre, de Firma Electrónica y, a nivel europeo, el **Reglamento nº 910/2014 del Parlamento Europeo y del Consejo**, de 23 de julio de 2014, relativo a la identificación electrónica y los servicios de confianza para las transacciones electrónicas en el mercado interior (*Electronic Identification and Signature IDAS*).

Podemos observar el flujo derivado del funcionamiento de la firma digital en los siguientes diagramas:

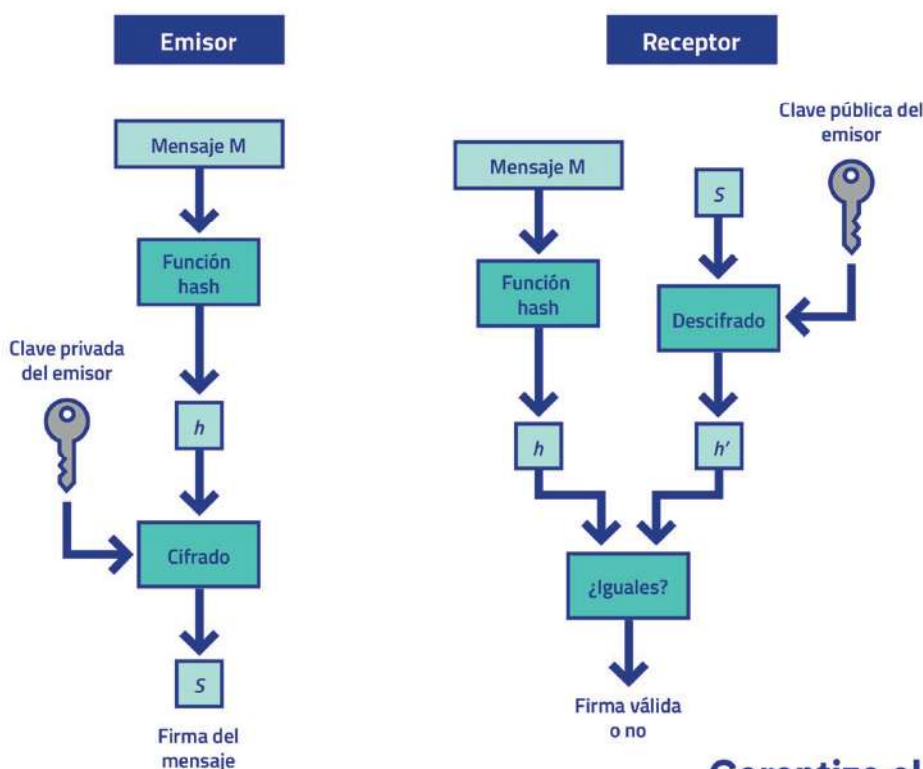


Figura 54

Garantiza el no repudio

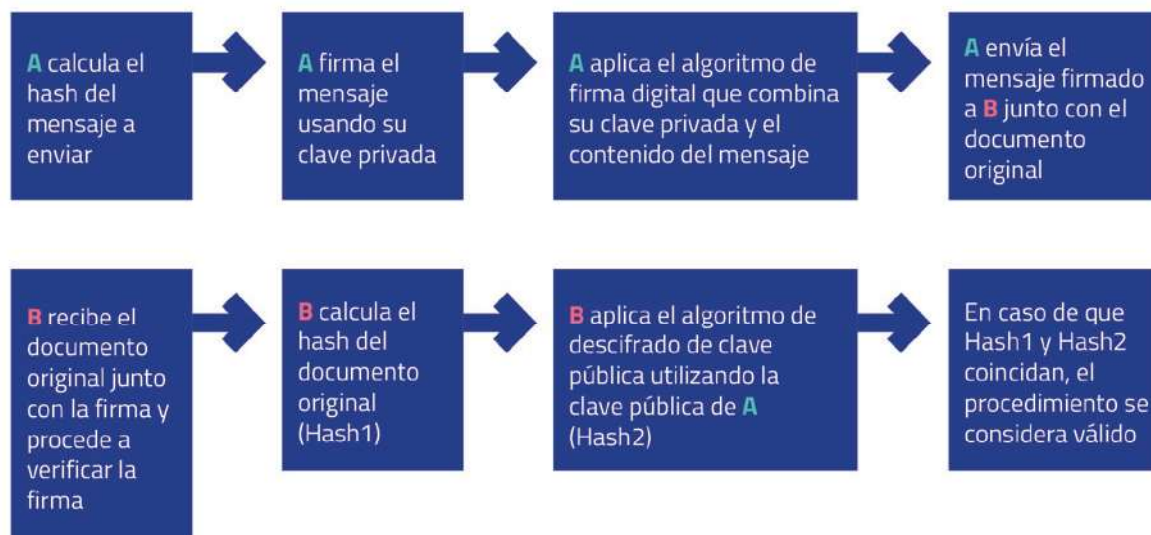


Figura 55

Veamos ahora las **principales diferencias entre firma manuscrita y digital**:

Firma manuscrita	Firma digital
▪ Varía según el firmante ▪ Igual independientemente del documento	▪ Varía según el firmante ▪ Varía en función del documento que se firme

Figura 56

6.2 Certificados digitales

Los certificados digitales constituyen un **sistema destinado a verificar la identidad real de forma inequívoca** a la hora de realizar **trámites online**.



Figura 57

Existen **dos tipos de certificados** dependiendo de **quién los ha emitido**:

- **Emitidos por una CA.** Son los que se utilizan principalmente en internet, donde una **autoridad certificadora** ha validado que, efectivamente, ese certificado pertenece a quien dice ser. Podemos encontrarlos en las páginas web, tal y como se muestra en la siguiente imagen:

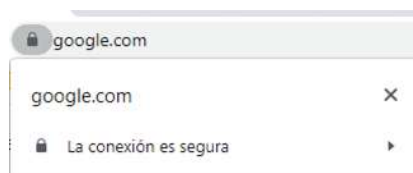


Figura 58

- **No emitidos por una CA.** Se trata de certificados que han sido autofirmados por quien los genera, de modo que cualquiera podría crear uno de ellos haciéndose pasar por otra persona. En este sentido, estos certificados pueden contar con mecanismos de cifrado más seguros que los validados por una CA, pero no se consideran confiables porque no se sabe quién está detrás de ellos.

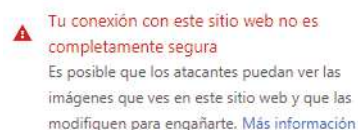


Figura 59

Certificados X.509

El certificado digital X.509 es un formato estándar para certificados de clave pública. Estos certificados incluyen la siguiente información:

- **Versión.** Se trata de la versión del certificado.
- **Número de serie.** Número de identificador único asignado por la CA en el momento de la creación del certificado.
- **Identificador del algoritmo de firmado.** Determina el algoritmo empleado para firmar el certificado (como RSA).
- **Nombre del emisor.** Identifica la CA que ha emitido y firmado el certificado.
- **Fechas de validez.** Por razones de seguridad, un certificado no puede ser permanente, es decir, siempre debe contar con una fecha de expiración que exige su posterior renovación.
- **Nombre del sujeto.** Campo que identifica a la entidad certificadora. Puede referirse a una persona o a una máquina.
- **Clave pública.** Se trata del campo más importante del certificado, pues contiene la clave pública en sí.
- **Huella digital.** Valor *hash* del certificado que permite identificarlo de manera única.

Formatos de codificación de los certificados

Los certificados se encuentran disponibles en diferentes formatos para su codificación y, aunque los más habituales son los formatos PEM y DER también podemos encontrar otros como el formato P7B o PFX.

El formato PEM es el más empleado y aunque su extensión típica es *.pem* esta no es la única, ya que puede adoptar otras como *.cer*, *.crt* o *.key* (en el caso de la clave privada). Este formato es empleado en Apache y en todos los servidores de Linux.

Por otro lado el formato DER es otro de los más comunes, y además de la extensión *.der* también es frecuente encontrarlo con extensión *.cer*. Este tipo de certificado es habitual emplearlo en plataformas Java.

En la figura 60 podemos ver las principales características de estos dos formatos.

PEM	DER
▪ Formato ASCII, codificado en B64 ▪ Armaduras de inicio y fin ▪ Incrementa un 33% el espacio de almacenamiento	▪ Formato binario, de acuerdo al estándar ASN.1 ▪ Más eficiente en almacenamiento, pero más problemático y complejo en su manejo

Figura 60

Ejemplo de tipo PEM:

```
-----BEGIN CERTIFICATE-----
MIIFtzCCBSCgAwIBAgIEPRmluDANBgkqhkiG9w0BAQUFADA2MQswCQYDVQGEwJF
UzENMAsGAIUEChMERK5NVDEYMBYGA1UECwMPCk5NCBDbGFZSSAyIENBMB4XDTE0
MDgwNDE3MzI1MFoXDTE3MDgwNDE3MzI1MFowYExCZAJBgNVBAYTAKVMTQ0wCwYD
VQOKEwRGTk1UMRgwFgYDVQLEw9GCTk1UIENsYXNlIDJlQ0EjAQBgNVBAsTCTcw
MzAxNTAxMzE1MDMGA1UEAxMsTk9NQlJFIERFTedBRE8gTU9IQVRBUiBPUNBNBUIAt
IE5JRiAwNTkyMDY3M0owggEiMA0GCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCcr
qrllwYQD08hwsHP1S9Qlel6j4d57BWHIrlsDEj8AXaqe6cVnJF+InrnTP49VhPAP
CV6kjAskqgTrXJ+E4IfZX3MmQOAKtT4IXs/Tiw/hUQuR+Il6AwOTXOwKuRgwdOI
2VJH2ium4ZljqPeFRBn2LHXqlwNEPAIaFyJiQ4G5wQGA39HI/XQHApRjPAYGibH
wh8soJ3GSh7LEiXzXRJWQn867OgAbs4CXWYuX7FP8yIUeyfg4Q6JYGaoyZCEdJOz
....
RgEBMBUGBgQAjkyBAJALEwNFVICAQAwXAYDVROFBFwUzBRoE+gTaRLMEKx
CzAJBgNVBAYTAKVMTQ0wCwYDVQKEwRGTk1UMRgwFgYDVQLEw9GCTk1UIENsYXNl
IDJlQ0EjETAPBgNVBAMTCENSTDEIMjMwMA0GCSqGSIb3DQEBAQUAA4GBADddiCiS
k6Etach7Q9Rj3UqfsEQnFYj3NVJLnt5BZT+jZgyhrpoEE58Ev0sRcK6zy05nwdLQ
7azT8nC2lQ30XQbPjT5eEnlQnSS0tH89nIFVokeQo96MZGYMchzQz/YfbVlx2E
mINoQLZp8t9EfmIOHQJZuqbW6db73iKcZol
-----END CERTIFICATE-----
```

Figura 61

Ejemplo de DER:

ASN.1 JavaScript decoder

```

SEQUENCE (3 elem)
  SEQUENCE (4 elem)
    INTEGER 0
    SEQUENCE (7 elem)
      SET (1 elem)
        SEQUENCE (2 elem)
          OBJECT IDENTIFIER 2.5.4.6
          PrintableString IR
      SET (1 elem)
        SEQUENCE (2 elem)
          OBJECT IDENTIFIER 2.5.4.8
          UTF8String Tehran
      SET (1 elem)
        SEQUENCE (2 elem)
          OBJECT IDENTIFIER 2.5.4.7
          UTF8String Tehran
      SET (1 elem)
        SEQUENCE (2 elem)
          OBJECT IDENTIFIER 2.5.4.10
          UTF8String Company
      SET (1 elem)
        SEQUENCE (2 elem)
          OBJECT IDENTIFIER 2.5.4.11
          UTF8String Section
      SET (1 elem)
        SEQUENCE (2 elem)
          OBJECT IDENTIFIER 2.5.4.3
          UTF8String Ebrahim
      SET (1 elem)
        SEQUENCE (2 elem)
          OBJECT IDENTIFIER 1.2.840.113549.1.9.1
          IA5String ebr.ghasemi at gmail
    SEQUENCE (2 elem)
      SEQUENCE (2 elem)
        OBJECT IDENTIFIER 1.2.840.113549.1.1.1
        NULL
      BIT STRING (1 elem)
        SEQUENCE (2 elem)
          INTEGER (1024 bit) 158907914395444502606077360020186567629617497425056671448582740484415...
          INTEGER 65537
      [0] (0 elem)
    SEQUENCE (2 elem)
      OBJECT IDENTIFIER 1.2.840.113549.1.1.11
      NULL
  BIT STRING (1024 bit) 10000101100001010000110011100100000001000000111111010001001111000001...

```

30	82	01	CB	30	82	01	34	02	01	00	30	81	8A	31	0B
30	09	06	03	55	04	06	13	02	49	52	31	0F	30	00	06
03	55	04	08	0C	06	54	65	68	72	61	6E	31	0F	30	00
06	03	55	04	07	0C	06	54	65	68	72	61	6E	31	10	30
0E	06	03	55	04	0A	0C	07	43	6F	60	70	61	6E	79	31
10	30	0E	06	03	55	04	08	0C	07	53	65	63	74	69	6F
6E	31	10	30	0E	06	03	55	04	03	0C	07	45	62	72	61
68	69	6D	31	23	30	21	06	09	2A	86	48	86	F7	00	01
09	01	16	14	65	62	72	2E	67	68	61	73	65	6D	69	20
61	74	20	67	6D	61	69	6C	30	81	9F	30	00	06	09	2A
86	48	86	F7	00	01	01	01	05	00	03	81	8D	00	30	81
89	02	81	81	00	E2	4A	D9	85	0E	49	11	23	AC	36	D9
6A	E0	B7	FF	9D	30	34	E0	08	FB	18	EA	27	6C	7D	E3
B0	AD	48	8C	AE	3D	22	EE	A6	50	D6	E2	80	24	BD	AA
98	BC	0E	68	70	8C	5E	00	66	D6	F5	66	45	FC	E7	4C
F3	3E	57	A1	01	77	FA	88	06	B0	49	DA	D5	36	4D	D5
36	39	5C	E7	68	46	02	2E	F6	01	40	D8	A4	4D	3E	39
C4	64	89	2D	EC	52	C1	25	44	25	93	96	A2	B6	19	38
95	FC	BB	D0	70	A8	A2	C8	D6	53	00	4E	29	A7	39	64
82	8E	B9	71	07	02	03	01	00	01	A0	00	30	00	06	09
2A	86	48	86	F7	00	01	01	08	05	00	03	81	81	00	85
85	0C	E4	02	07	E8	9E	0C	CF	F4	42	95	FA	84	F0	56
1A	A4	43	B6	DF	CB	94	C4	F3	96	08	47	76	B2	9A	EC
DB	BC	07	3D	29	67	56	C9	D3	B1	1E	21	EA	5D	B9	99
10	25	AF	2E	53	2C	AE	5A	E9	C8	33	B6	5F	1C	BC	51
71	49	90	D8	07	E1	1C	AC	DB	AE	C4	4D	AA	18	87	5F
61	B5	CE	2A	67	33	6A	2B	FD	5E	8D	00	54	89	D8	18
42	86	9F	27	1B	F7	62	13	BE	81	8A	F6	B7	1C	B1	30
13	74	7A	D7	2A	B8	49	70	C7	4A	1D	17	C2	B1	54	

Figura 62

Ejercicio de reflexión

Abrir el almacén de certificados de nuestro navegador y estudiar el de alguna CA raíz.

Revocación de certificados

Revocar un certificado consiste en anular el mismo antes de que venza la fecha de caducidad que figura en él. Esta revocación se puede realizar en cualquier momento y normalmente sucede cuando el titular del certificado considera que sus claves privadas han sido vulneradas.

Existen dos maneras de revocar certificados, aunque ambas han recibido numerosas críticas:

- **CRL (listas de revocación).** Lista de números de serie revocados firmados por la CA correspondiente. Estos certificados por tanto ya no son válidos y no se debe de confiar en ellos. En España el periodo de validez de un certificado es de cinco años como máximo, lo cual obliga a tener que renovarlos o sino pasarán a la lista de revocación, también pueden encontrarse en esta lista aquellos donde el titular lo ha solicitado debido a condiciones especiales como una orden judicial, pérdida de confidencialidad, claves expuestas, etc.
- **OCSP.** Protocolo de verificación de un certificado en tiempo real, permite determinar el estado de vigencia de un certificado digital X.509.

CA comerciales y gratuitas

Las Autoridades de Certificación (CA) son las entidades que avalan y respaldan los certificados, son las responsables de su emisión y de su revocación. La siguiente imagen muestra las CA más conocidas en la actualidad:



Figura 63

Entre ellas, cabe destacar a Let's Encrypt, pues se trata de una CA gratuita, libre y muy fácil de utilizar.

Certificados *wildcard*

Los certificados SSL *wildcard* también reciben el nombre de “certificados de asterisco”. Se trata de un **tipo universal del certificado SSL** que permite **asegurar todos los subdominios bajo un dominio principal**. El certificado *wildcard* incluye, junto al nombre del dominio principal, un **asterisco** (por ejemplo *.example.com) y su uso permite ahorrar gastos de compra de otros certificados SSL, así como el tiempo que requiere su instalación y gestión.



Figura 64

Ejercicio de reflexión

Localizar tres subdominios que utilicen un *wildcard*.

6.3 Hash

Una función *hash* o resumen es una **función unidireccional cuyo resultado es un identificador unívoco e irreplicable de cualquier tipo de entrada** (texto, imagen, etc.).

Desempeña, principalmente, las siguientes funciones:

- Transformar un conjunto de datos mediante operaciones matemáticas por cada conjunto de bits de un tamaño constante.
- Se emplea en criptografía y cuenta con distintos niveles de complejidad.
- Actualmente, se usa en el ámbito de las criptomonedas.

Existen varias funciones para la realización de un *hash*, aunque muchas de ellas no deberían usarse, pues se trata de algoritmos que, por colisiones, han roto su **unidireccionalidad**. Son, básicamente, las siguientes:

- MD5: no recomendado.
- SHA1: no recomendado.
- SHA2: recomendado.
- SHA3: recomendado.

Las principales propiedades que aportan estas funciones se aplican a los siguientes casos de uso:

1. Verificación de contraseñas.
2. Comprobación de la integridad de archivos y mensajes.
3. *Hashing* y ciberseguridad.
4. Generación y verificación de firmas electrónicas.

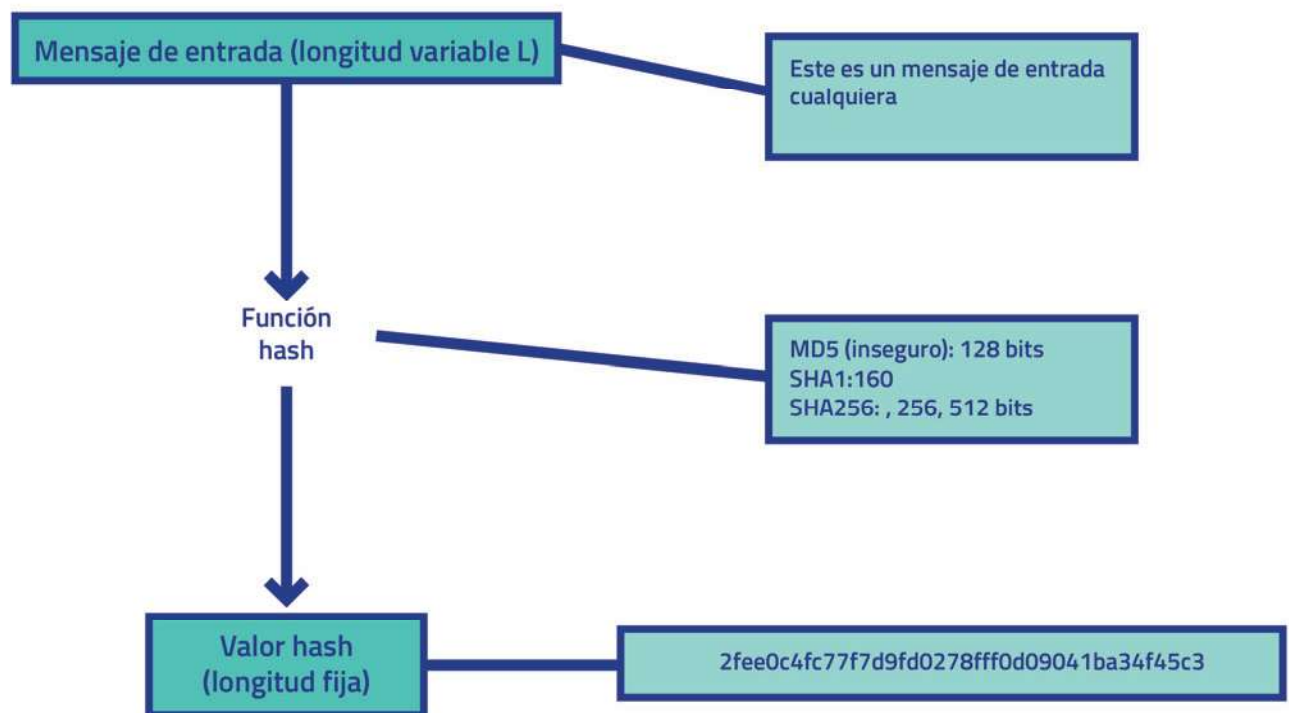


Figura 65